

HOP 1 – auth exemption

hooks.server.ts:
~/api/git/stacks/<id>/webhook\$ as
RegExp exemption
listed isPublicPath:
no session required
TRUST BREAK 1: pre-auth by design

HOP 2 – null-secret guard

if (webhookSecret)
wraps the signature check;
schema default text
(NULL), free tier
TRUST BREAK 2: NULL skips auth

HOP 3 – deploy entry

deployGitStack(id,
{force:false})
first sync after create
updated=true
forceRedeploy stock flag
makes every hit fire

PAYOFF – host root

container binds / -j
uid=0 on managed host
flag loot, page served on
172.30.53.20:8080
scope change: panel -j host

HOP 5 – the sink

deployStack:
docker compose up -d
against the mounted
managed docker.sock
panel's full host authority
this is what executes

HOP 4 – attacker text lands

syncGitStack:
git clone of tracked
branch (S-C commit)
compose /:/hostroot
lands in /app/data/stacks/

POST, no signature

guard skipped

sync

compose file

execve

fix at 1,2

v1.0.40 fix semantics (verified in lab): signature check is *mandatory*, a NULL secret answers 401; creation refuses webhookEnabled without a secret; shared verifyWebhookSignature() with constant-time compare; and git-url-safety.ts refuses ext::/fd::/file:// URLs, option-leading refs, and composePath escapes of the clone dir.